MK CONSULTS

INITIAL GAP ANALYSIS: READINESS SUMMARY

Information Security Management System (ISMS): ISO/IEC 27001:2022

Document ID: ISMS-GAP-001

Version 1.0 | 28 August 2026

Classification: Internal

Document owner: CISO, ISMS champion (Levi Hartley)

Approved by: CEO (Maya Ellington)

MK Consults is a fictitious company. All figures and findings are illustrative and created for educational purposes.

Document Control

Field	Entry
Organisation	MK Consults, Berlin, Germany
Document title	Initial Gap Analysis: Readiness Summary
Document ID	ISMS-GAP-001
Version	1.0
Classification	Internal
Document owner	CISO, ISMS champion (Levi Hartley)
Prepared by	CISO, ISMS champion (Levi Hartley)
Approved by	CEO (Maya Ellington)
Date issued	28 August 2026
Assessment period	17 to 28 August 2026
ISO/IEC 27001:2022 reference	Clauses 4 to 10 and Annex A, including Amendment 1:2024
Review trigger	Superseded by the detailed gap assessment report once the ISMS scope is approved
Storage	ISMS document library (Confluence), version controlled

Version History

Version	Date	Author	Summary of change
0.1	26 August 2026	CISO (Levi Hartley)	Draft prepared following interviews and document review
1.0	28 August 2026	CISO (Levi Hartley)	Issued to the CEO (Maya Ellington) for review and approval

Contents

Document Control..... 2
Version History..... 2
1. Executive Summary..... 4
2. Purpose, Scope and Method..... 4
3. Results: Clauses 4 to 10..... 6
4. Results: Annex A Controls..... 6
5. Key Gaps..... 7
6. Estimated Effort..... 8
7. Implications and Recommendations..... 8
8. Approval..... 9
Appendix A: Clause Requirement Ratings..... 10
Appendix B: Annex A Control Ratings..... 12
Appendix C: Supporting Records..... 15

1. Executive Summary

MK Consults is not ready for ISO/IEC 27001:2022 certification today. Security practice is functional and the technical foundations are reasonable, but there is no information security management system: no policy, no risk process, no internal audit and no management review. None of the 30 requirements in Clauses 4 to 10 is fully met.

The gap is mainly in the management system, not in technology. That makes it achievable with internal effort, a full-time project manager and targeted external support, rather than large tool investment.

Headline results

Area	Requirements	Yes	Partially	No
Clauses 4 to 10	30	0	9	21
Annex A controls (93)	93	21	34	38

What it will take

- **Effort:** an estimated 185 to 215 internal person-days over the project, plus external support for the detailed gap assessment, internal audit and penetration testing.
- **People:** a full-time ISMS Project Manager, with part-time contribution from IT, HR, Finance and client delivery.
- **Timeline:** about 12 months from kick-off in September 2026, giving a realistic certification window of June to September 2027.
- **Budget:** set out in the business case, with a Year 1 envelope of EUR 49,580.

Recommendation

Proceed. Present the business case to the leadership team at the Management Awareness Session in September 2026, secure management commitment, and formally initiate the ISMS project.

2. Purpose, Scope and Method

2.1 Purpose

To establish, with evidence, how far MK Consults is from the requirements of ISO/IEC 27001:2022, and to size the effort, resources, cost and time needed to reach certification. The findings inform the business case.

2.2 Working scope

No ISMS scope has been formally defined. This analysis used a working scope: all MK Consults employees and contractors; the AWS environment; Microsoft 365; GitHub; the SaaS stack used for client delivery; and the remote workforce. The Berlin office is treated as a registered address only. The formal scope will be defined in the ISMS Scope Statement once the project starts.

2.3 Method

The assessment covered every requirement of Clauses 4 to 10 and made a quick pass through all 93 Annex A controls. Evidence was gathered through:

- interviews with the owners of each area (Section 2.4);
- review of documents provided in response to a document request list;
- light observation, including screen-shares of user administration and MFA settings.

Each requirement was rated using the scale below. Ratings are recorded in the gap analysis workbook.

Rating	Meaning
Yes	Documented, operating, and evidence seen
Partially	Done but not documented, documented but not done, or inconsistent
No	Not in place

2.4 People interviewed

Interviewee	Date	Focus
CEO (Maya Ellington)	19 Aug 2026	Clauses 4 and 5, risk appetite, objectives, management review
Head of IT (Liam Whitmore)	20 Aug 2026	Document control, operations, technological controls
HR Manager (Frederick Ashworth)	20 Aug 2026	Competence, awareness, people controls
Finance Manager (Kylian Pemberton)	21 Aug 2026	Suppliers, asset purchasing, budget
Senior Consultant, client delivery (Iwami Thornton)	24 Aug 2026	Handling of client data during engagements
External Legal and Compliance Advisor (Ryan Kingsley)	24 Aug 2026	Legal, regulatory and contractual requirements

2.5 Limitations

- This is a high-level assessment against a working scope. Annex A ratings rest mainly on interviews, with evidence checked only where quick to obtain.
- Security was partly self-assessed by the CISO acting as ISMS champion. Ratings in security-owned areas were held to a higher evidence bar to offset this.
- Annex A results show which controls exist today. They do not determine which controls apply: that will be decided through risk treatment and recorded in the Statement of Applicability.
- A detailed gap assessment with full evidence will follow once the ISMS scope is approved.

3. Results: Clauses 4 to 10

Clauses 4 to 10 are mandatory and cannot be excluded. The overall rating for each clause reflects the balance of its requirements.

Clause	Reqs	Yes	Partially	No	Overall	Key finding
Clause 4: Context	4	0	2	2	Partially	Requirements known informally; nothing documented; no scope
Clause 5: Leadership	3	0	1	2	No	No policy, no defined roles; sponsorship informal
Clause 6: Planning	5	0	0	5	No	No risk method, register, treatment, SoA or objectives
Clause 7: Support	7	0	4	3	Partially	Skilled people; no awareness programme or document control
Clause 8: Operation	3	0	1	2	No	Operations run well, but no defined security processes
Clause 9: Performance evaluation	6	0	0	6	No	No metrics, internal audit or management review
Clause 10: Improvement	2	0	1	1	Partially	Fixes happen; no nonconformity log or root cause analysis
Total	30	0	9	21		

The requirement-level ratings are in Appendix A.

4. Results: Annex A Controls

A quick pass was made through all 93 controls. Results are summarised by Annex A section. Many A.7 physical controls for data centre infrastructure are provided by AWS under the shared responsibility model; their applicability will be confirmed through risk treatment.

Section	Controls	Yes	Partially	No	Main observations
A.5 Organizational	37	4	12	21	No asset inventory, no supplier security reviews, no incident procedure or continuity plan
A.6 People	8	2	4	2	NDAs in contracts; no screening procedure or awareness training
A.7 Physical	14	6	3	5	Data centre controls inherited from AWS; home working equipment rules missing
A.8 Technological	34	9	15	10	MFA on most core systems but not enforced; managed laptops; backups not tested; logging not reviewed
Total	93	21	34	38	

The control-level ratings are in Appendix B.

5. Key Gaps

The gaps with the greatest effect on readiness, in priority order:

#	Gap	Evidence
1	No information security policy or defined roles (5.2, 5.3)	No approved policy found; security duties informal between CISO and Head of IT
2	No risk assessment or treatment process (6.1, 8.2, 8.3)	No method, acceptance criteria, register or SoA
3	No ISMS scope (4.3)	Not defined; working scope used for this analysis
4	No internal audit or management review (9.2, 9.3)	Neither has ever been carried out
5	No document control (7.5)	No ID, versioning or approval convention; documents scattered across Confluence and SharePoint
6	No security awareness programme (7.3)	No training records for the last 12 months
7	No asset inventory or supplier security reviews (A.5)	No inventory provided; supplier contracts reviewed only commercially
8	MFA not enforced on all systems; backups untested (A.8)	MFA admin console showed exceptions; no restore test records

Strengths to build on

- Supportive CEO who sponsored this analysis.
- Experienced, certified security and IT staff.
- Cloud-first infrastructure on AWS and Microsoft 365, with managed, encrypted laptops.
- MFA already in place on most core systems.
- Client and regulatory requirements well understood from existing contracts and questionnaires.

6. Estimated Effort

Estimates are in person-days (one person working one full day). They are planning figures and will be refined after the detailed gap assessment and risk treatment.

Work area	Person-days	Type of work
Context, interested parties and scope (Clause 4)	8	Write
Policy, roles and responsibilities (Clause 5)	6	Write
Risk method, assessment, treatment plan and SoA (Clause 6, 8)	25	Build
Objectives and measurement (Clauses 6.2, 9.1)	9	Build
Competence and awareness (Clauses 7.2, 7.3)	8	Build
Document control and communication (Clauses 7.4, 7.5)	6	Build
Operational procedures (Clause 8.1)	5	Write
Internal audit programme and management review (Clauses 9.2, 9.3)	7	Build
Nonconformity and corrective action process (Clause 10)	3	Build
Control implementation (Annex A, subject to risk treatment)	90 to 120	Implement
Certification audit support and finding treatment	18	Support
Total	185 to 215	

External support is assumed for the detailed gap assessment, the independent internal audit and penetration testing. Costs are set out in the business case.

7. Implications and Recommendations

1. **Proceed with an ISO/IEC 27001:2022 implementation.** The gaps are significant but achievable within about 12 months.
2. **Appoint a full-time ISMS Project Manager.** The management system work alone is too large to run alongside a day job.
3. **Secure the budget in the business case,** including external support for the detailed gap assessment, internal audit and penetration testing.
4. **Target a certification window of June to September 2027,** allowing at least two to three months of ISMS operation before the Stage 1 certification audit.
5. **Define the ISMS scope early in the project** and run a detailed gap assessment against it before the risk assessment.

Next steps

Action	Owner	Date
Finalise the business case using these findings	CISO (Levi Hartley)	4 Sep 2026
Present the business case at the Management Awareness Session	CISO (Levi Hartley)	7 to 16 Sep 2026
Decide on management commitment and resources	CEO (Maya Ellington)	18 Sep 2026

8. Approval

By signing below, the CEO confirms that these findings have been reviewed and accepts them as the basis for the ISO 27001 business case.

Role	Name	Signature	Date
Prepared by	CISO, ISMS champion (Levi Hartley)		
Approved by	CEO (Maya Ellington)		

Appendix A: Clause Requirement Ratings

Ref	Requirement	Rating	Finding
4.1	Organizational context	Partially	Issues are understood informally (client demands, remote working, AWS reliance) but have never been documented or reviewed.
4.2	Interested parties	Partially	Client and regulatory requirements are known from contracts and questionnaires; no register, and no decision on which requirements the ISMS addresses.
4.3	ISMS scope	No	No scope defined. Working scope assumed for this analysis.
4.4	ISMS established	No	No management system in place.
5.1	Leadership and commitment	Partially	CEO supportive and sponsoring this analysis; no formal commitment, resources or accountability yet.
5.2	Information security policy	No	No approved policy. Informal acceptable-use expectations only.
5.3	Roles and responsibilities	No	Security responsibilities sit informally with the CISO and Head of IT; not defined or communicated.
6.1.1	Risks and opportunities	No	Not addressed.
6.1.2	Risk assessment	No	No method, no acceptance criteria, no risk register.
6.1.3	Risk treatment and SoA	No	No treatment process, no Statement of Applicability.
6.2	Security objectives	No	No measurable objectives.
6.3	Planning of changes	No	No planned change process for security.
7.1	Resources	Partially	Skilled people and tooling exist; no resources allocated to an ISMS.
7.2	Competence	Partially	Security and IT staff experienced and certified; competence requirements and records not defined.
7.3	Awareness	No	No awareness programme; last company-wide session could not be evidenced.
7.4	Communication	Partially	Ad hoc security messages via Slack; no communication plan.
7.5.1	Documented information	No	No defined set of ISMS documents.
7.5.2	Creating and updating	No	No document identification, versioning or approval convention.
7.5.3	Control of documented information	Partially	Confluence and SharePoint used with access controls; no retention or change control rules.
8.1	Operational planning and control	Partially	Technical operations run well day to day; no defined security processes or control of outsourced services beyond standard contracts.
8.2	Risk assessment performed	No	Never performed.
8.3	Risk treatment implemented	No	Never performed.
9.1	Monitoring and measurement	No	No security metrics or reporting.
9.2.1	Internal audit	No	Never performed.
9.2.2	Audit programme	No	None.
9.3.1	Management review	No	Never held.
9.3.2	Review inputs	No	No review inputs defined.

Ref	Requirement	Rating	Finding
9.3.3	Review results	No	None.
10.1	Continual improvement	Partially	Improvements happen after incidents, informally.
10.2	Nonconformity and corrective action	No	Incidents fixed as they arise; no log and no root cause analysis.

Appendix B: Annex A Control Ratings

Ratings record which controls exist today, based mainly on interviews. They do not determine which controls apply: that is decided through risk treatment and recorded in the Statement of Applicability.

A.5 Organizational controls

Ref	Control	Rating	Observation
5.1	Policies for information security	No	No information security policy or topic-specific policies.
5.2	Information security roles and responsibilities	Partially	Security duties held informally by the CISO and Head of IT; not defined.
5.3	Segregation of duties	Partially	Some separation in finance approvals; not assessed for security.
5.4	Management responsibilities	No	No management requirement to follow security policies.
5.5	Contact with authorities	No	No contact list for authorities.
5.6	Contact with special interest groups	Yes	Active memberships in security and GRC professional bodies.
5.7	Threat intelligence	No	No threat intelligence process.
5.8	Information security in project management	No	Security not part of internal or client project methodology.
5.9	Inventory of information and other associated assets	No	No asset inventory.
5.10	Acceptable use of information and other associated assets	Partially	Acceptable use expectations exist informally; no approved policy.
5.11	Return of assets	No	No offboarding checklist covering return of assets.
5.12	Classification of information	No	No classification scheme.
5.13	Labelling of information	No	No labelling.
5.14	Information transfer	Partially	Encrypted transfer used for clients; no rules or agreements.
5.15	Access control	Partially	Access granted by role in practice; no access control policy.
5.16	Identity management	Partially	Unique accounts via Microsoft 365; no joiner, mover, leaver process.
5.17	Authentication information	Yes	Company password manager in use; credentials issued securely.
5.18	Access rights	Partially	Access requested by ticket; no periodic access reviews.
5.19	Information security in supplier relationships	No	No supplier security risk process.
5.20	Addressing information security within supplier agreements	Partially	Standard provider terms and DPAs in place; security clauses not reviewed.
5.21	Managing information security in the ICT supply chain	No	ICT supply chain not assessed.
5.22	Monitoring, review and change management of supplier services	No	No supplier service reviews.
5.23	Information security for use of cloud services	Partially	AWS and Microsoft 365 used securely; shared responsibility not documented.

Ref	Control	Rating	Observation
5.24	Information security incident management planning and preparation	No	No incident management plan.
5.25	Assessment and decision on information security events	No	No event triage criteria.
5.26	Response to information security incidents	Partially	Incidents handled ad hoc by IT; no procedure.
5.27	Learning from information security incidents	No	No post-incident reviews.
5.28	Collection of evidence	No	No evidence handling procedure.
5.29	Information security during disruption	No	No continuity plan covering security.
5.30	ICT readiness for business continuity	No	No ICT continuity or recovery objectives.
5.31	Legal, statutory, regulatory and contractual requirements	Partially	Requirements understood via external legal advisor; no register.
5.32	Intellectual property rights	Yes	Software licensed through managed SaaS subscriptions; IP clauses in contracts.
5.33	Protection of records	Partially	Records stored in Microsoft 365 with access control; no retention schedule.
5.34	Privacy and protection of PII	Yes	GDPR records of processing, privacy notices and DPIAs maintained with legal advisor.
5.35	Independent review of information security	No	No independent review of security.
5.36	Compliance with policies, rules and standards for information security	No	No compliance checks.
5.37	Documented operating procedures	No	Operating procedures not documented.

A.6 People controls

Ref	Control	Rating	Observation
6.1	Screening	Partially	References checked for new hires; no screening procedure.
6.2	Terms and conditions of employment	Yes	Employment contracts include confidentiality and security obligations.
6.3	Information security awareness, education and training	No	No awareness or training programme.
6.4	Disciplinary process	Partially	HR disciplinary process exists; does not reference security.
6.5	Responsibilities after termination or change of employment	Partially	Contract clauses survive termination; not communicated at exit.
6.6	Confidentiality or non-disclosure agreements	Yes	NDAs signed by staff, contractors and key third parties.
6.7	Remote working	Partially	Remote working practices in place; no policy.
6.8	Information security event reporting	No	No defined channel for reporting security events.

A.7 Physical controls

Ref	Control	Rating	Observation
7.1	Physical security perimeters	Yes	Data centre perimeters provided by AWS; office in managed building.
7.2	Physical entry	Yes	Badge entry to office building; AWS data centre entry controls.
7.3	Securing offices, rooms and facilities	Partially	Office locked; no physical security standard.
7.4	Physical security monitoring	Yes	Building security monitoring; AWS data centre monitoring.
7.5	Protecting against physical and environmental threats	Yes	Environmental protection provided by AWS and building management.
7.6	Working in secure areas	No	No secure area rules.
7.7	Clear desk and clear screen	Partially	Screen lock enforced through MDM; no clear desk rule.
7.8	Equipment siting and protection	No	No guidance for siting equipment at home.
7.9	Security of assets off-premises	Partially	Laptops encrypted; no rules for using equipment off-premises.
7.10	Storage media	No	No removable media controls.
7.11	Supporting utilities	Yes	Supporting utilities resilience provided by AWS.
7.12	Cabling security	Yes	Cabling security provided by AWS and building management.
7.13	Equipment maintenance	No	No maintenance records for equipment.
7.14	Secure disposal or re-use of equipment	No	No secure disposal or wipe records.

A.8 Technological controls

Ref	Control	Rating	Observation
8.1	User endpoint devices	Yes	Laptops MDM-enrolled, encrypted and protected.
8.2	Privileged access rights	Partially	Admin accounts limited; not reviewed; some shared admin use.
8.3	Information access restriction	Partially	Permissions set per system; not aligned to a policy.
8.4	Access to source code	Yes	GitHub permissions and branch protection in place.
8.5	Secure authentication	Partially	MFA on most core systems; exceptions found; not enforced everywhere.
8.6	Capacity management	Yes	AWS monitoring and autoscaling in place.
8.7	Protection against malware	Yes	Endpoint protection deployed and up to date.
8.8	Management of technical vulnerabilities	Partially	Patching done; no vulnerability scanning or SLAs.
8.9	Configuration management	Partially	Infrastructure partly defined as code; no documented baselines.
8.10	Information deletion	No	No deletion rules.
8.11	Data masking	No	No data masking.
8.12	Data leakage prevention	No	No data leakage prevention.
8.13	Information backup	Partially	Backups run automatically; restores never tested.

Ref	Control	Rating	Observation
8.14	Redundancy of information processing facilities	Yes	Multi-zone AWS architecture.
8.15	Logging	Partially	Logs collected in AWS and Microsoft 365; not reviewed.
8.16	Monitoring activities	No	No security monitoring or alerting.
8.17	Clock synchronization	Yes	Clocks synchronised through AWS and Microsoft 365.
8.18	Use of privileged utility programs	No	No control of privileged utility programs.
8.19	Installation of software on operational systems	Partially	MDM limits installation on laptops; no procedure for servers.
8.20	Networks security	Partially	AWS security groups in place; no network diagram or reviews.
8.21	Security of network services	Yes	Network services provided under AWS and Microsoft agreements.
8.22	Segregation of networks	Yes	Environments separated in distinct AWS accounts and VPCs.
8.23	Web filtering	No	No web filtering.
8.24	Use of cryptography	Partially	Encryption at rest and in transit enabled; no cryptography policy.
8.25	Secure development life cycle	Partially	Development practices exist; no secure development policy.
8.26	Application security requirements	Partially	Some security requirements in tickets; not systematic.
8.27	Secure system architecture and engineering principles	No	No secure architecture principles.
8.28	Secure coding	Partially	Code reviewed through pull requests; no secure coding standard.
8.29	Security testing in development and acceptance	Partially	Some automated code scanning; no security testing procedure.
8.30	Outsourced development	No	Outsourced development not controlled; use to be confirmed.
8.31	Separation of development, test and production environments	Yes	Development, test and production in separate AWS accounts.
8.32	Change management	Partially	Changes approved through pull requests; no change procedure for infrastructure.
8.33	Test information	No	No rules for test data.
8.34	Protection of information systems during audit testing	No	No rules of engagement for audit testing.

Appendix C: Supporting Records

- Gap analysis workbook (Clauses 4 to 10 and Annex A ratings, with comments)
- Interview notes for each interviewee
- Documents received in response to the document request list

The ratings in Appendices A and B are also recorded, with comments, in the gap analysis workbook.